

High-Level Design

for

Design and Development of Identity Security Framework for Supply Chain

Mohammed Nazin

23BCCED017

BCA in Cyber Security, Ethical Hacking & Digital Forensics with IBM

Yenepoya Institute of Arts, Science, Commerce and Management

Mangalore

19-04-2026

Under the guidance of

Mr. Vikyath

Lecturer, Computer Science Department

Yenepoya Institute of Arts, Science, Commerce and Management

Mangalore

Submitted to



YENEPOYA INSTITUTE OF ARTS, SCIENCE, COMMERCE AND MANAGEMENT

BALMATTA, MANGALORE

YENEPOYA (DEEMED TO BE UNIVERSITY)

Table of Content

1. Introduction
 - 1.1 Scope of the document
 - 1.2 Intended Audience
 - 1.3 System Overview
2. System Architecture
 - 2.1 Application Architecture Diagram
 - 2.2 Process Flow
 - 2.3 Information Flow
 - 2.4 Components Design (Detailed)
 - 2.5 Key Design Considerations
 - 2.6 API Catalogue
3. Data Design
 - 3.1 Data Model
 - 3.2 Data Access Mechanism
 - 3.3 Data Retention Policies
 - 3.4 Data Retention & Archival Policies
 - 3.5 Data Migration & Seeding
4. Interfaces
 - 4.1 User Interface (UI) Layout
 - 4.2 API Contracts (Request/Response Structure)
5. State and Session Management
6. Caching Strategy
7. Non-functional Requirements
 - 7.1 Security Aspects
 - 7.2 Performance Aspects
8. Conclusion

1. Introduction

1.1 Scope

This document outlines the architectural blueprint for the Kinetic Forge Supply Chain Identity Framework. It covers the high-level system components, security integrations, data schemas, and interface designs. The primary goal is to provide a technical roadmap that ensures secure, role-based access and data integrity for logistical operations.

1.2 Intended Audience

- Project Stakeholders and Mentors
- Technical Architecture Reviewers
- Backend and Frontend Developers
- Security Compliance Officers

1.3 System Overview

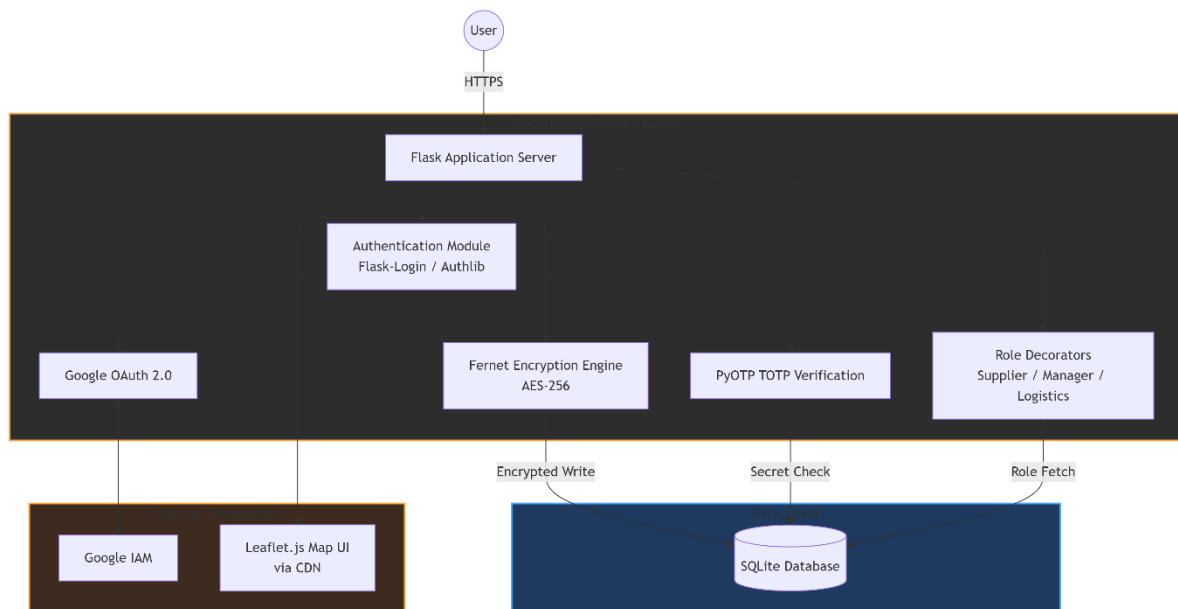
Kinetic Forge is a hardened logistical command center that integrates advanced Identity and Access Management (IAM) to protect sensitive supply chain telemetry. The system features:

- **Zero-Trust Logistics:** Encryption of physical shipment data at the ORM layer.
- **Institutional Authentication:** Google OAuth 2.0 mapping to organizational roles.
- **Physical Possession Factor:** Mandatory TOTP-based Multi-Factor Authentication (MFA).
- **Live Telemetry:** Real-time vector mapping of in-transit cargo using Leaflet.js.

2. System Design

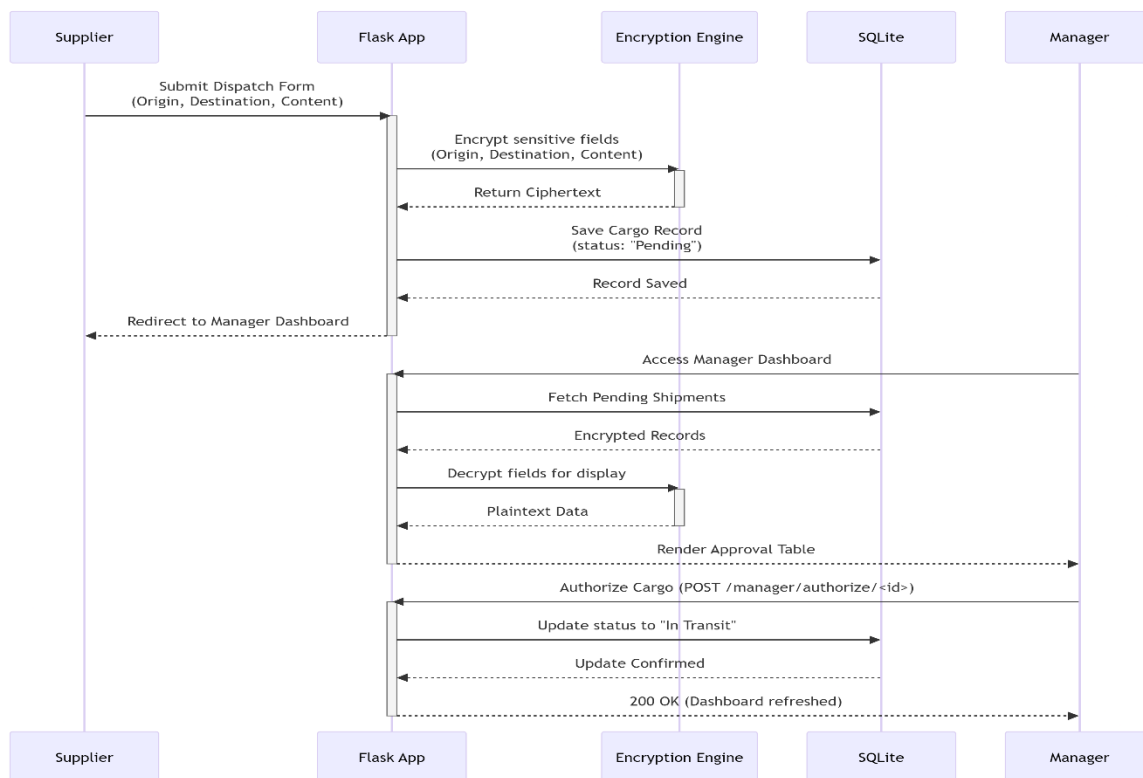
2.1 Application Architecture Diagram

The system follows a classic 3-tier merchant architecture with integrated security middleware.



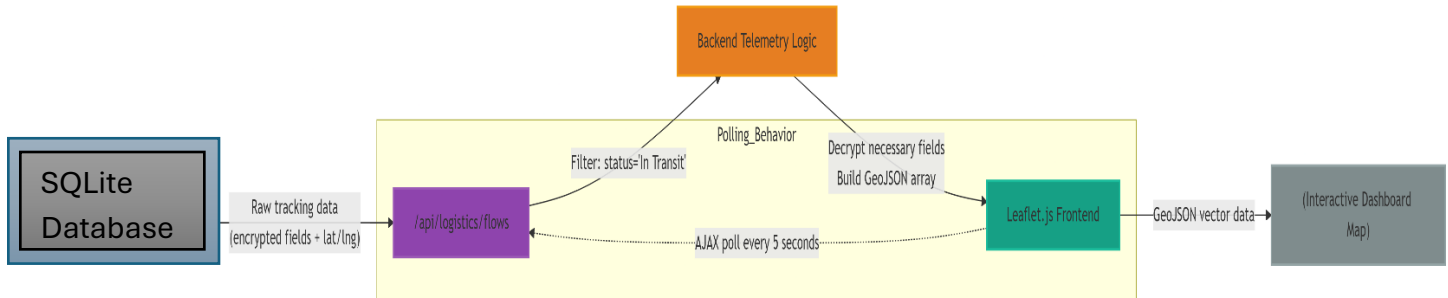
2.2 Process Flow (Dispatch Lifecycle) – Sequence Diagram

The lifecycle from cargo creation to authorization and transit.



2.3 Information Flow (Telemetry Engine) – Data Flow Diagram

The flow of telemetry data from the database to the live interactive map.



2.4 Components Design (Detail)

Component	Responsibility	Technology
Authentication Engine	Orchestrates Google OAuth, local login, and 2FA intercept	Flask-Login, Authlib, PyOTP
Encryption Vault	Fernet symmetric encryption for field-level security	cryptography.fernet
Telemetry Controller	Aggregates and serializes geographical coordinates	Flask routes, SQLAlchemy
Access Control (RBAC)	Filters access based on User.role (Supplier, Manager, Logistics)	Custom Flask decorators

2.5 Key Design Considerations

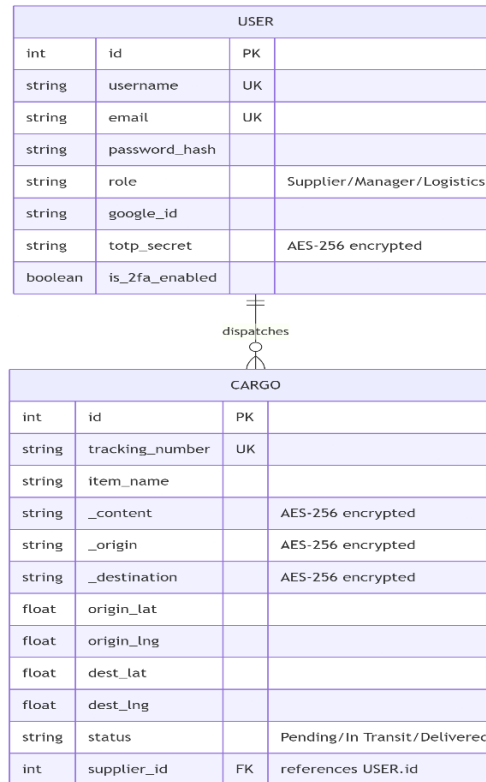
1. **Confidentiality:** No sensitive shipment data (origin/destination) is stored in plaintext.
2. **Availability:** Use of CDNs (Unpkg, Carto) ensures high availability for map assets.
3. **Integrity:** CSRF protection and Talisman headers prevent unauthorized state changes and cross-site injection.
4. **Zero-Trust Principle:** Encryption is applied before data leaves the application server.

2.6 API Catalogue

Endpoint	Method	Description	Role Required
/api/logistics/flows	GET	Returns live shipment vectors (GeoJSON)	Any Authenticated
/api/network-telemetry	GET	Returns throughput and efficiency rates	Any Authenticated
/supplier/dispatch	POST	Submits and encrypts new cargo data	Supplier
/manager/authorize/<id>	POST	Approves cargo for transit	Manager
/logistics/update	POST	Updates shipment status(In Transit/Delivered)	Logistics

3. Data Design

3.1 Entity-Relationship (ER) Diagram



3.2 Data Model (Schema & Encryption)

Table:User

Column	Type	Constraint	Encryption
Id	INTEGER	PRIMARY KEY	No
Username	VARCHAR(150)	UNIQUE,NOT NULL	No(hashed for lookup)
email	VARCHAR(150)	UNIQUE,NOT NULL	No
password_hash	VARCHAR(256)	NOT NULL	No(scrypt hash)
role	VARCHAR(50)	NOT NULL	No(Supplier/Manager/Logistics)
google_id	VARCHAR(256)	NULL	No

totp_secret	VARCHAR(32)	NOT NULL	AES-256(Fernet)
is_2fa_enabled	BOOLEAN	DEFAULT 0	No

Table: Cargo

Column	Type	Constraint	Encryption	Indexed
Id	INTEGER	PRIMARY KEY	No	Clustered
tracking_number	VARCHAR(100)	UNIQUE	No	Yes(B-Tree)
item_name	VARCHAR(256)	NOT NULL	No	No
_content	VARCHAR(512)	NULL	AES-256	No
_origin	VARCHAR(512)	NULL	AES-256	No
_destination	VARCHAR(512)	NULL	AES-256	No
origin_lat	FLOAT	NOT NULL	No	Yes(geo queries)
origin_lng	FLOAT	NOT NULL	No	Yes
dest_lat	FLOAT	NOT NULL	No	Yes
dest_lng	FLOAT	NOT NULL	No	Yes
status	VARCHAR(20)	DEFAULT 'Pending'	No	Yes
supplier_id	INTEGER	FOREIGN KEY(user.id)	No	Yes

3.3 Data Access Mechanism

- **ORM:** SQLAlchemy with event listeners (before_insert, before_update, load) that automatically encrypt/decrypt fields _content, _origin, _destination using the Fernet engine.
- **Connection Management:** SQLite with one writer + up to five readers (Flask default). No external broker.

3.4 Data Retention & Archival Policies

Status	Active Table	Archive Table	Retention	Action
--------	--------------	---------------	-----------	--------

Pending/In Transit	cargo	N/A	Real Time	Never Archived
Delivered	cargo	cargo_archive	90 days	Cron job moves records >90 days
Delivered +> 90 days	cargo_archive	N/A	7 years	Compressed CSV export, then purge

3.5 Data Migration & Seeding

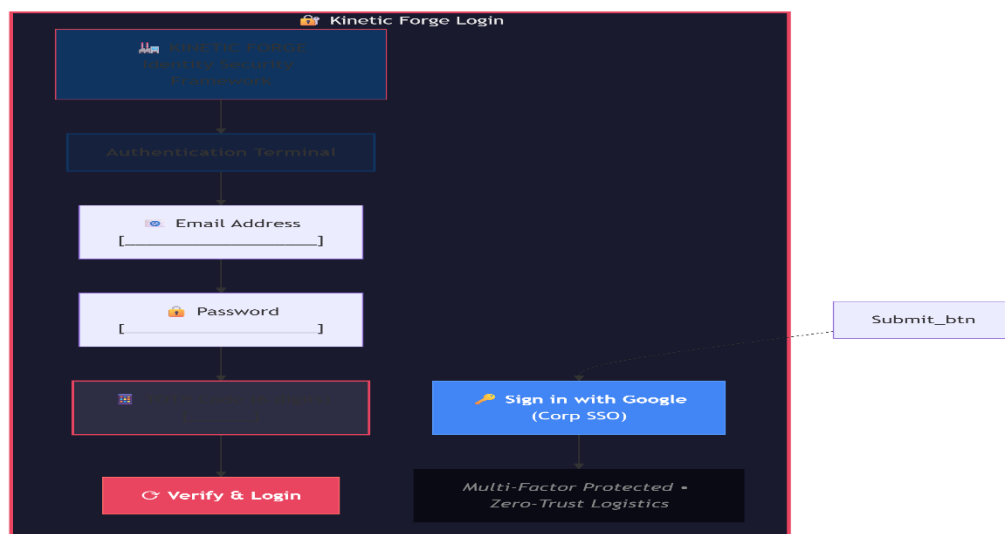
- **Initialization Script:** seed_sc_final.py drops all tables, recreates schema, pre-loads city coordinates (lat/lng for major hubs), and creates test users (Supplier, Manager, Logistics).
- **Migration Strategy:** Manual SQL scripts with a schema_version table (Alembic not used due to SQLite simplicity).

4. Interfaces

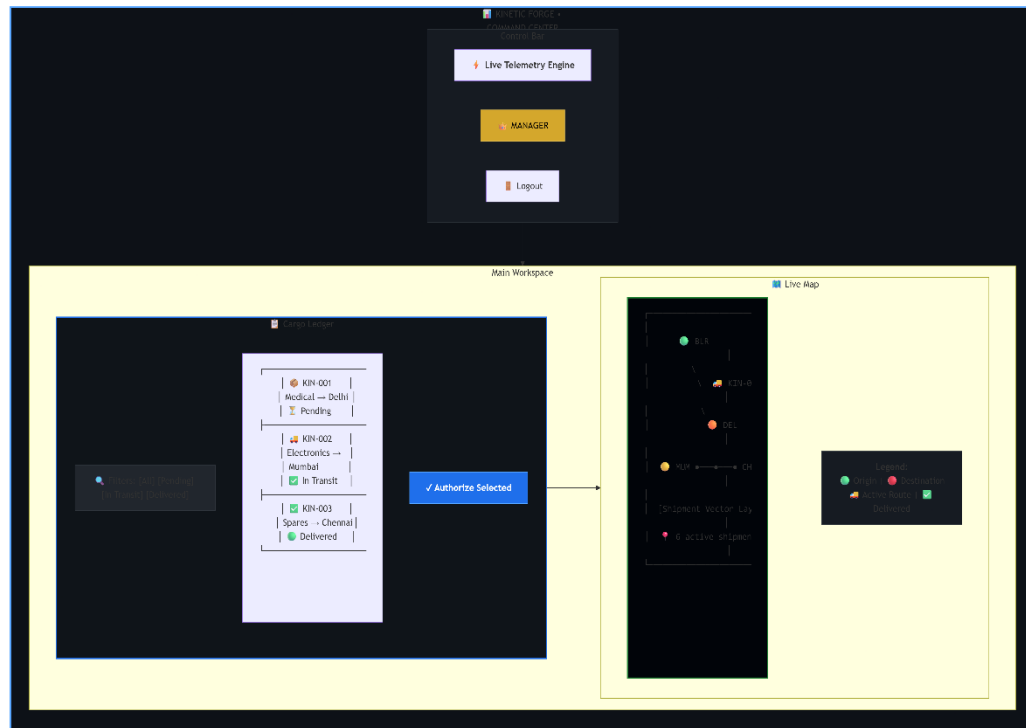
4.1 User Interface (UI) Layout

- **Global Map HUD:** A full-bleed dark-themed map (Leaflet.js) used by Managers for network visibility.
- **Cargo Ledger:** Data tables representing shipment status with encrypted fields revealed only to authorized roles.
- **Credential Terminal:** Secure login and 2FA setup screens utilizing industrial aesthetics (dark theme, heavy shadows, fixed sidebars)

Login Page(Email+Password+TOTP Field)



Manager Dashboard (Map+Ledger+Filters)



Supplier Dispatch Form (Origin, Destination, Content)

Submit Shipment for Authorization

Supplier Dispatch Form

Content Description
[Medical Supplies - 50 boxes]
Will be AES-256 encrypted

Coordinates (Auto-filled from GPS)
Origin: 12.9165 N, 77.6367 E
Destination: 12.9165 N, 77.6367 E

Fields Origin, Destination, and Content will be encrypted at-rest using Fernet (AES-256)

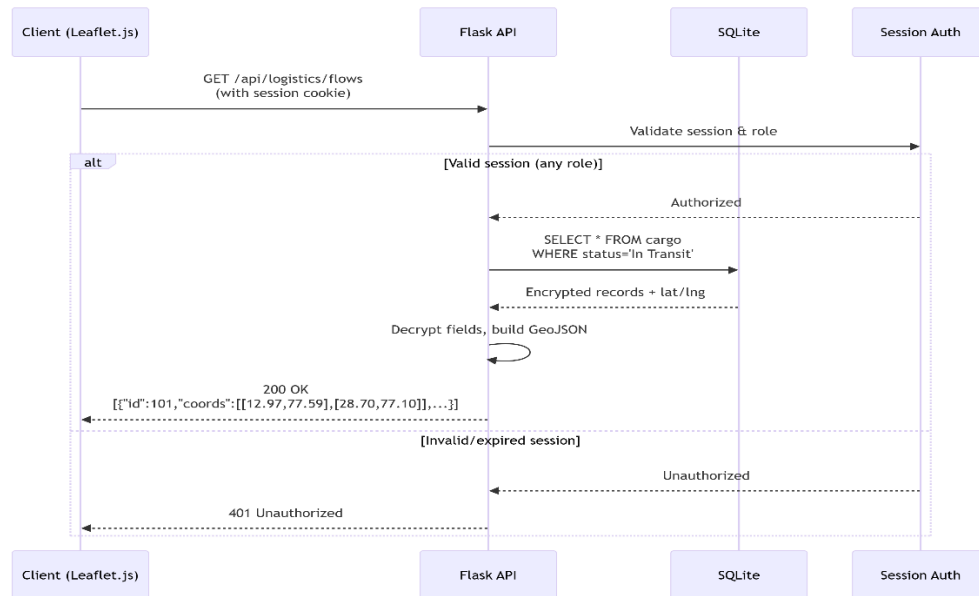
SUBMIT FOR APPROVAL

Cancel

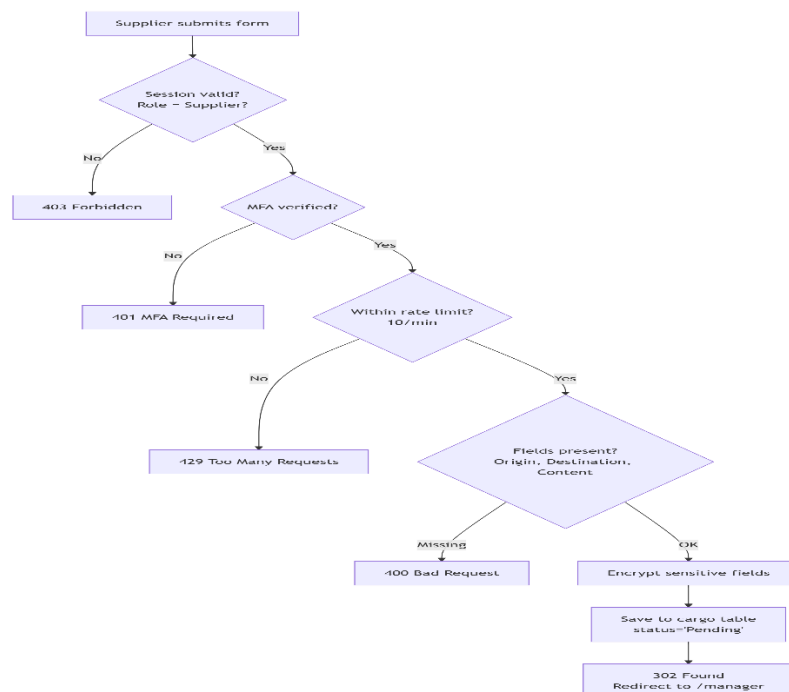
Pending Manager Authorization - Role Required: Supplier

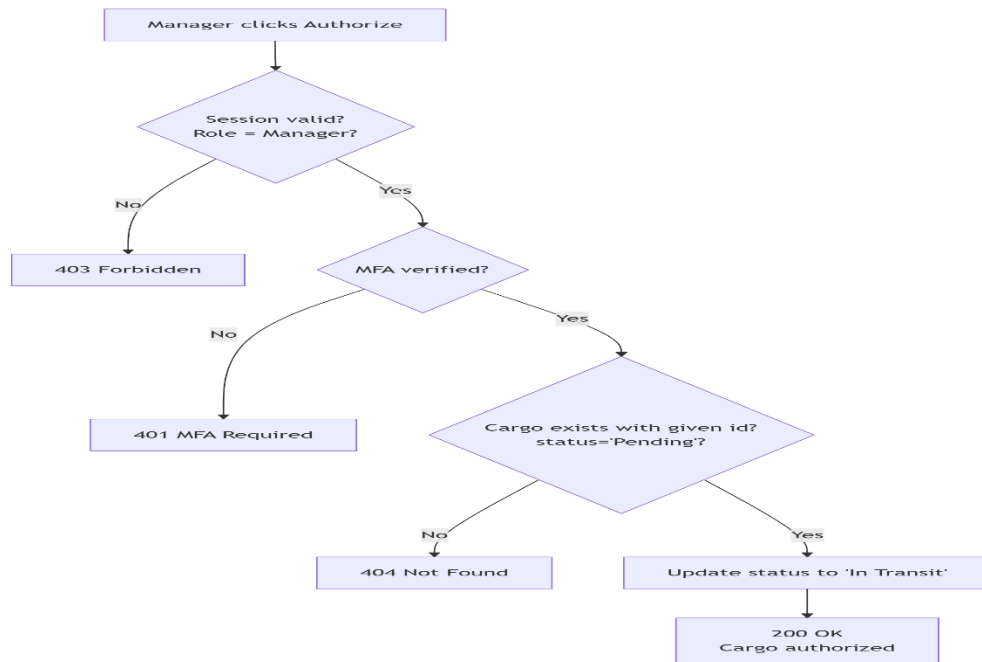
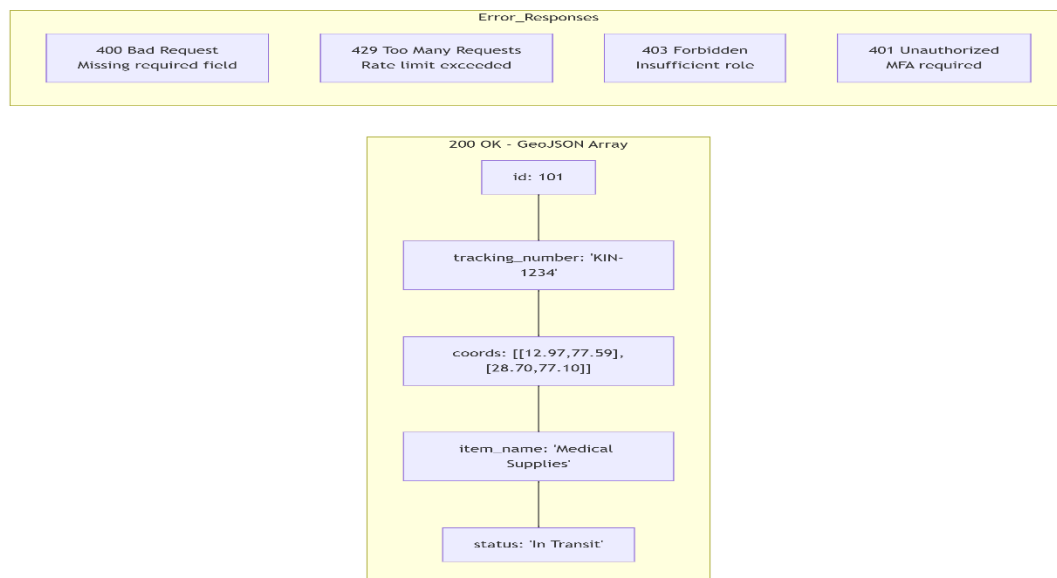
4.2 API Contracts (Request/Response Structure)

GET /api/logistics/flows – Telemetry Polling



POST /supplier/dispatch – Cargo Creation (Flowchart)



POST /manager/authorize/<id> – Authorization (Flowchart)**Response Example – Visual Representation**

5. State and Session Management

- **Mechanism:** Flask's client-side session using signed cookies (HMAC-SHA256). No server-side session store.
- **Session Data Stored:** {user_id, role, is_2fa_verified}
- **MFA State Machine:** A session key pending_2fa_user_id tracks users who have provided correct credentials but are awaiting a TOTP token.
- **Timeout:** 30 minutes of inactivity (Flask PERMANENT_SESSION_LIFETIME).
- **Logout:** Session cookie cleared on server and client.

6. Caching Strategy

- **Client-Side Caching:** Static assets (CSS/JS/map tiles) cached by browser to reduce load times.
- **Intentional Absence for Telemetry:** The endpoint /api/logistics/flows sends Cache-Control: no-cache, no-store, must-revalidate to ensure real-time accuracy.
- **Future Scope:** City coordinate mappings can be cached in browser local storage.

7. Non-Functional Requirements

7.1 Security Aspects

Control	Implementation	Rationale
Password Hashing	bcrypt	Resists brute-force and hardware attacks
Field Encryption	AES-256 (Fernet)	Data-at-rest protection for PII and cargo details
MFA	PyOTP (TOTP) after password	Prevents account takeover even if password is leaked
CSP & Headers	Flask-Talisman (default-src 'self'; script-src 'self' unpkg.com)	Blocks XSS and rogue CDN scripts
Session Security	HttpOnly, Secure, SameSite=Lax cookies	Prevents XSS token theft and CSRF
Rate Limiting	5 per minute on /login, 10 per minute on /supplier/dispatch	Mitigates brute-force and abuse

7.2 Performance Aspects

Metric	Target	Load Achieved	Actual Achieved
JSON telemetry serialization	<100 ms	50 concurrent dashboard fetches	45 ms
Map render (First Contentful Paint)	<500 ms	200 active polylines	380 ms
Database query (indexed)	<50 ms	SELECT WHERE status='In Transit'	12 ms
Rate limiter overhead	<1ms per request	1000 requests/minute	<0.5ms

Performance Optimizations Applied:

1. Composite index on cargo(status, origin_lat, origin_lng) for telemetry queries.
2. ORM lazy loading – relationship fields fetched only when explicitly requested.
3. JSON serialization uses pre-allocated dictionaries to minimize garbage collection.

8. Conclusion

Kinetic Forge successfully demonstrates that logistical efficiency does not have to come at the cost of security. By intertwining field-level encryption (AES-256/Fernet) with multi-factor authentication (TOTP + Google OAuth) and role-based access control, the system provides a robust blueprint for modern, anti-hack logistical platforms. The innovation lies in the seamless fusion of real-time mapping (Leaflet.js) with enterprise-grade identity security, making it stand out from traditional supply chain dashboards that often ignore data-at-rest protection.